

Ошибки путаницы привилегий: подделка межсайтовых запросов в веб-приложениях

Реферат

Кичигина Полина Евгеньевна

Содержание

1	Введение	3
2	Механизм CSRF-атак	4
3	Почему CSRF называют ошибкой путаницы привилегий	5
4	Основные методы защиты от CSRF	6
5	Пример реальной уязвимости	8
6	Заключение	9
7	Список литературы	10

1 Введение

Подделка межсайтовых запросов (Cross-Site Request Forgery, CSRF) — тип атаки на веб-приложения, относящийся к классу ошибок «путаница доверенного лица». Злоумышленник заставляет браузер аутентифицированного пользователя выполнить нежелательное действие на доверенном сайте без ведома жертвы. Проблема актуальна из-за автоматической отправки cookies аутентификации браузером при каждом запросе к сайту.

2 Механизм CSRF-атак

Для успешной CSRF-атаки необходимы три ключевых условия:

1. Пользователь аутентифицирован на целевом веб-сайте — его сессионные cookies активны и действительны.
2. Целевой сайт не имеет эффективной защиты от CSRF.
3. Злоумышленник может предсказать или сформировать запрос, который выполняет «чувствительное» действие (изменение пароля, перевод денег, удаление данных).

Типовой сценарий атаки:

- Жертва предварительно входит на легитимный сайт (например, интернет-банк) и получает сессионные cookies.
- Злоумышленник размещает на своём сайте вредоносную HTML-форму или ссылку, которая автоматически отправляет запрос на целевой сайт.
- Жертва переходит на страницу злоумышленника (или нажимает на ссылку в письме).
- Браузер жертвы автоматически отправляет поддельный запрос на сервер, прикладывая cookies аутентификации.
- Сервер, не видя разницы между запросами, выполняет действие.

Важная особенность CSRF — «слепота» атаки: злоумышленник не видит ответ сервера. Поэтому CSRF применима к операциям, изменяющим состояние сервера, но не подходит для кражи данных напрямую.

3 Почему CSRF называют ошибкой путаницы привилегий

Проблема «confused deputy» возникает, когда компонент системы (браузер) имеет привилегии и использует их, выполняя инструкции от другого компонента, но не может проверить его истинные намерения. Браузер отправляет запрос на сервер, даже если он инициирован вредоносным сайтом, потому что браузеру «всё равно», кто создал запрос. Сервер доверяет браузеру и cookies. В результате злоумышленник «одурачивает» браузер, заставляя его действовать от имени жертвы.

4 Основные методы защиты от CSRF

1. CSRF-токены.

Самый надёжный метод — использование синхронных токенов. Сервер генерирует уникальный криптостойкий токен для сессии или для каждой формы. Токен встраивается в HTML-форму. При отправке запроса клиент возвращает токен. Сервер проверяет его корректность; при неверном или отсутствующем токене запрос отклоняется.

2. Double Submit Cookie.

Метод «двойной отправки cookie» не требует хранения состояния на сервере. Сервер устанавливает cookie со случайным значением. Клиент при отправке запроса читает это значение из cookie и передаёт его в теле запроса или заголовке. Сервер сравнивает значения — при совпадении запрос считается легитимным.

3. Атрибут SameSite для cookies.

Современные браузеры поддерживают атрибут SameSite, контролирующий отправку cookies при кросс-сайтовых запросах:

- SameSite=Strict — cookies не отправляются при любых кросс-сайтовых запросах.
- SameSite=Lax — cookies отправляются только при навигации верхнего уровня (переход по ссылке), но не при отправке форм.
- SameSite=None — cookies отправляются всегда (требуется Secure).

Установка SameSite=Lax для сессионных cookies защищает от большинства CSRF-атак без дополнительных усилий.

4. Валидация заголовков Referer и Origin.

Дополнительная мера — проверка заголовков Referer или Origin. Сервер проверяет, что источник запроса соответствует ожидаемому домену. Метод не является основным, так как заголовки могут отсутствовать или подделываться в устаревших браузерах.

5 Пример реальной уязвимости

Уязвимости CSRF до сих пор обнаруживаются. В системе MISP Modules версии 3.0.7 выявлена уязвимость CVE-2026-44364: отсутствие CSRF-защиты позволяло злоумышленнику заставить аутентифицированного пользователя изменить данные сессии.

6 Заключение

CSRF-атаки — классический пример ошибки путаницы привилегий. Несмотря на наличие современных средств защиты (SameSite, CSRF-токены), ответственность за безопасность лежит на разработчике. Рекомендуется комбинировать методы: использовать CSRF-токены для критических операций и правильно настраивать SameSite для cookies. Регулярный аудит и следование стандартам OWASP минимизируют риск эксплуатации CSRF.

7 Список литературы

CSRF-уязвимость: что это, примеры и надежная защита

<https://codeby.net/threads/mezhsaitovaya-poddelka-zaprosa-csrf-nakhodim-i-obezvrezhivayem-gaid-dlya-nachinayushchikh.85892/>

Веб-безопасность 201 / Хабр

<https://habr.com/ru/companies/oleg-bunin/articles/570034/>

CSRF-атака: что это такое, как работает и как защититься - журнал "Код"

<https://thecode.media/csrf-ataka-chto-eto/>